

ACTIRA

Agentic Cybersecurity Threat Intelligence & Incident Response Advisor

Capstone Project 4 | Advanced Certification Programme in Agentic and Generative AI

26 July 2026 | Enterprise Pilot Ready (78/100)

Group 1 team - see Appendix E

Generated from docs/capstone/PROJECT_REPORT.md and appendices/. For editable source and full test tables, use the Markdown pack.

Agentic Cybersecurity Threat Intelligence & Incident Response Advisor (ACTIRA)

Capstone Project Report

Program: Advanced Certification Programme in Agentic and Generative AI

Project number: 4 (TalentSprint Capstone Projects List)

Product codename: ACTIRA

Date: 26 July 2026

Maturity label: Enterprise Pilot Ready (single-tenant)

Enterprise board score: 78 / 100

Fill institute/team fields on the title page per program template before PDF export.

Pack root: docs/capstone/ (all report materials stay under this folder).

PPTX: presentation/ACTIRA_Capstone_Presentation.pptx - Appendices: appendices/ - Assets: assets/

Pack layout (this folder only)

```
docs/capstone/
??? PROJECT_REPORT.md          <- this report
??? README.md
??? appendices/                <- Appendices A-F (full content)
?   ??? A_test_case_catalog.md
?   ??? B_api_surface.md
?   ??? C_sample_outputs.md
?   ??? C_sample_g001.json
?   ??? D_configuration.md
?   ??? E_team_roles.md
?   ??? F_glossary.md
??? assets/
?   ??? screenshots/           <- demo figures for PDF
?   ??? figures/               <- architecture diagrams
??? board/
?   ??? CAPSTONE_BOARD_REVIEW_AND_SUBMISSION.md
??? outlines/
?   ??? PROJECT_REPORT_OUTLINE.md
??? presentation/
    ??? ACTIRA_Capstone_Presentation.pptx
    ??? PPT_OUTLINE.md
    ??? build_capstone_pptx.js
```

Abstract

ACTIRA is an AI-assisted Security Operations platform that automates multi-format log ingestion, Indicator of Compromise (IoC) extraction, threat-intelligence enrichment, MITRE ATT&CK mapping, hybrid Retrieval-Augmented Generation (RAG), and citation-grounded incident response (IR) playbook generation, with mandatory Human-in-the-Loop (HiTL) review for high-risk cases. The system is implemented as a modular FastAPI and React application backed by MongoDB and LanceDB, with multi-provider LLM support, cross-provider fallbacks, offline golden evaluation, and enterprise-oriented controls (RBAC, secrets vault, audit trail with integrity hashing, compliance alignment scoring).

Offline golden IR evaluation on 37 cases yields mean IoC F1 ~ 0.98, mean technique recall ~ 0.93, full NIST-style playbook phase coverage, and zero case errors under template playbooks-providing a reproducible CI gate independent of live LLM APIs. The product exceeds a thin Gradio demo: investigation workspace, review queue, hunt, analytics, compliance evidence packs, and Docker/Kubernetes packaging support a single-tenant enterprise pilot narrative. Limitations include single-tenant deployment, heuristic ATT&CK mapping, dependence on external LLM/TI APIs for peak quality, and no claim to replace SIEM/XDR platforms of record (Sentinel, Splunk ES, Falcon, XSIAM).

Keywords: Agentic AI, RAG, MITRE ATT&CK, Human-in-the-Loop, SOC, Incident Response, LanceDB, FastAPI

Table of contents

- 1. Introduction
- 2. Literature & related work
- 3. System requirements
- 4. System architecture
- 5. Design & methodology
- 6. Implementation
- 7. Testing & evaluation
- 8. Results & discussion
- 9. Challenges & mitigations
- 10. Conclusion & future work
- References

Appendices (full text under appendices/)

ID	Title	File
A	Test case catalog	appendices/A_test_case_catalog.md
B	API surface	appendices/B_api_surface.md
C	Sample outputs	appendices/C_sample_outputs.md
D	Configuration	appendices/D_configuration.md
E	Team roles	appendices/E_team_roles.md
F	Glossary	appendices/F_glossary.md

Chapter 1 - Introduction

1.1 Background

Security Operations Centers (SOCs) face sustained growth in alert volume from SIEM, EDR, cloud, and network sensors. Analysts must extract IoCs, enrich them with threat intelligence (TI), map activity to MITRE ATT&CK, and produce actionable IR playbooks-often under time pressure and with inconsistent documentation. General-purpose LLM chatbots reduce typing but introduce hallucination, missing audit trails, and no formal human gate for high-risk actions.

1.2 Problem statement

Manual pipelines for parse -> IoC -> TI -> ATT&CK -> playbook are slow, non-reproducible, and poorly grounded in organizational knowledge bases. Commercial SOAR platforms are powerful but heavy, closed, and expensive for education and mid-market pilots. Capstone Project 4 asks for an agentic cybersecurity threat intelligence and IR advisor that closes this gap with open, explainable AI and human oversight.

1.3 Objectives

ID	Objective
01	Multi-format log ingest and structured event normalization
02	Automated IoC extraction and TI enrichment (live or mock)
03	MITRE ATT&CK technique mapping and visualization
04	Hybrid RAG over IR knowledge with citation-grounded playbooks
05	HiTL review for critical severity / low-grounding cases
06	Investigation workspace as system of record for a case
07	Offline golden evaluation and RBAC-hardened API
08	Deployable stack (Compose / Kubernetes) with ops docs

Non-functional: pilot-class latency, secret hygiene, auditability, honest data defaults (no silent demo KPI fill).

1.4 Scope and non-goals

In scope: single-tenant SOC console for upload-driven IR advising, workspace investigation, review, compliance alignment, multi-provider LLM.

Out of scope (explicit non-goals):

- * Replacement for Microsoft Sentinel, Splunk ES, CrowdStrike Falcon, Cortex XSIAM, or Google SecOps as SIEM/XDR of record
- * Multi-tenant SaaS isolation (v1)
- * Unsupervised SOAR execution / auto-remediation without human gate
- * Formal ISO/SOC2 certification (alignment score only)

1.5 Contributions

1. End-to-end modular IR pipeline with job queue and multi-format parsers
2. Hybrid BM25 + LanceDB vector retrieval with citation allow-listing
3. Investigation workspace (timeline, graph, notes, RCA, playbooks)
4. HiTL policy gates + review queue with audit
5. Offline golden IR suite (CI-gated metrics)
6. Wave C: compliance alignment score, audit integrity chain, executive export
7. Multi-provider LLM catalog (free/paid) with cross-provider fallback
8. React enterprise UI exceeding Gradio/Streamlit baseline of the capstone brief

1.6 Report organization

Chapters 2-3 establish context and requirements; 4-6 describe architecture, design, and implementation; 7-8 present evaluation and results; 9-10 cover challenges and future work. Appendices index tests, APIs, and configuration.

Chapter 2 - Literature & related work

2.1 RAG for knowledge-intensive tasks

Lewis et al. (2020) introduced Retrieval-Augmented Generation, combining parametric LLMs with non-parametric memory. ACTIRA applies hybrid lexical + dense retrieval (Reciprocal Rank Fusion) over IR playbook knowledge and enforces citation IDs within a known allow-list to reduce ungrounded advice.

2.2 MITRE ATT&CK and IR standards

MITRE ATT&CK provides a shared taxonomy of adversary techniques. NIST SP 800-61 structures incident handling (preparation, detection, containment, eradication, recovery, lessons learned). ACTIRA maps techniques heuristically from evidence and generates playbooks with NIST-style phases; timeline and RCA support kill-chain narrative without claiming full STIX/TAXII enterprise sync.

2.3 Agentic systems

Industry frameworks (LangGraph, CrewAI, AutoGen) emphasize multi-agent orchestration. ACTIRA implements a modular agentic pipeline-named stages (parse, enrich, map, retrieve, generate, gate)-rather than a full multi-agent swarm product. This choice prioritizes determinism, offline eval, and operational simplicity for pilot demos while remaining honest about "agentic" scope.

2.4 Commercial SOC platforms

Enterprise platforms excel at data lakes, connectors, and SOAR execution. ACTIRA does not compete on ingest scale; it competes on grounded IR narrative, HiTL, investigation workspace, and reproducible offline evaluation-complementary to SIEM dual-run pilots.

2.5 Research / product gap

Open stacks rarely combine (a) multi-format evidence -> (b) hybrid RAG playbooks with citations -> (c) mandatory HiTL -> (d) workspace UX -> (e) CI golden gates in one deployable package. ACTIRA targets that gap for education and single-tenant pilots.

Chapter 3 - System requirements

3.1 Personas

Persona	Needs	Primary surfaces
SOC Analyst	Fast triage, structured IR	Upload, Incidents, Workspace, Hunt
Senior Reviewer	Controlled approval	Review Queue, Audit
Admin	Keys, thresholds, health	Settings, Ops, Golden Benchmark
Executive (demo)	Risk snapshot	Dashboard, Compliance, Export

3.2 Functional requirements (summary)

FR	Description	Status
FR-1	Parse Apache/Nginx/Syslog/Windows + extended formats	Done
FR-2	Extract IP/domain/URL/hash IoCs	Done
FR-3	Enrich via AbuseIPDB/VT (mock without keys)	Done
FR-4	Map MITRE ATT&CK techniques	Done (heuristic)
FR-5	Hybrid RAG IR playbooks	Done
FR-6	HiTL for critical / low grounding	Done
FR-7	Dashboard KPIs & ATT&CK heatmap	Done (live default)
FR-8	Investigation workspace tabs	Done
FR-9	Auth + RBAC	Done
FR-10	Compliance alignment + audit integrity	Done (Wave C)

3.3 Non-functional requirements

NFR	Target	Approach
Security	Role isolation, vault, logout	Cookie sessions, RBAC matrix tests
Auditability	Who/what/when + integrity	SHA-256 audit chain
Latency	Pilot-class, demo <10 min golden path	Job queue, KPI cache
Honesty	No silent fake dashboard data	Demo fallback opt-in only
Deployability	Compose + Helm	deployments/

3.4 Success metrics

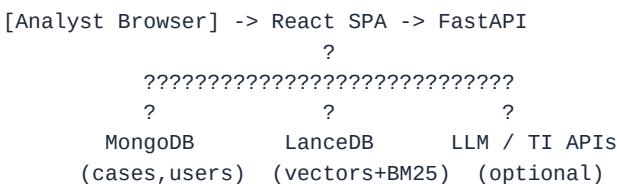
Metric	Target	Observed (2026-07-26)
Golden cases	>= 30	37
Mean IoC F1	>= 0.85	0.982
Mean technique recall	>= 0.80	0.930
Mean grounding	>= 0.50	1.0 (template path)
Full phase coverage	100%	1.0
Mean offline latency	<= 7 s	< 0.01 s
CI gate failures	0	0
Enterprise board score	Pilot	78/100

Chapter 4 - System architecture

4.1 Architecture style

ACTIRA is a modular monolith (ADR 0001): one backend process with clear router/service boundaries, dual API mounts (/api and /api/v1), and a React SPA. This optimizes demo reliability and single-tenant ops over premature microservices.

4.2 High-level context



4.3 Data flow

1. Upload multi-file/ZIP evidence -> job enqueued
2. Pipeline parse -> CES events -> IoC extract -> enrich -> ATT&CK -> RAG -> playbook
3. HiTL gate may force pending_review
4. UI Dashboard/Incidents/Workspace/Review consume REST (+ SSE for investigator)
5. Audit/Compliance record actions; executive export packages evidence

4.4 Component view

Layer	Responsibilities
Frontend	Auth, pages, design system, HelpTips
API routers	Auth, incidents, upload, review, hunt, settings, compliance, audit, eval
Services	Analytics KPIs, pipeline orchestration, LLM provider, vault
Engines	Parsers, IoC, enrichment, attack mapping, hybrid RAG, playbook agent, HiTL
Data	MongoDB documents; LanceDB hybrid index; optional file evidence

4.5 AI workflow

Hybrid retrieval (BM25 + dense, RRF, optional re-rank) feeds structured playbook generation. Grounding score and citation IDs constrain outputs. Multi-provider LLM layer selects free/paid models and falls back across providers; template playbooks ensure offline continuity.

4.6 Security architecture

- * Password login with logout; JWT session cookies
- * RBAC: analyst / senior_reviewer / admin
- * Secrets vault (encrypt-at-rest; never return raw keys)
- * ZIP bomb / size limits on ingest
- * Audit trail with integrity hashing
- * Compliance alignment score (not certification)

4.7 Deployment

Docker Compose for lab; Kubernetes/Helm charts under deployments/. Environment via .env and Settings UI vault. CI: GitHub Actions for tests and golden gates.

Chapter 5 - Design & methodology

5.1 Datasets and knowledge bases

- * Synthetic multi-format logs under samples/
- * Golden IR dataset (backend/tests/golden/dataset.json, 37 cases)
- * MITRE-oriented technique catalog and IR playbook KB in LanceDB
- * Optional CVE/KEV enrichment when configured

5.2 Log analysis pipeline

Parsers normalize heterogeneous sources (Apache, Nginx, Syslog, Windows-oriented formats, Suricata, Zeek, Sysmon, Defender). Correlated events form Common Event Schema (CES) records feeding IoC and technique inference. Pipeline isolation ensures one bad file does not abort the batch.

5.3 IoC extraction and TI enrichment

Regex/heuristics extract IPs, domains, URLs, hashes. Private IPs are filtered from public enrichment. Without API keys, enrichment returns mock results for offline demos; with keys, AbuseIPDB, VirusTotal, and additional providers apply. FORCE MOCK_TI forces deterministic mock mode for tests.

5.4 ATT&CK mapping

Keyword and pattern heuristics map evidence to technique IDs (e.g., brute-force -> T1110-class). Optional LLM refine can improve narrative; heatmaps and incident filters expose technique prevalence. Mapping is not a full enterprise ATT&CK engine.

5.5 Hybrid RAG

Lexical BM25 + LanceDB vectors fused by RRF; optional Cohere re-rank. Design choice of LanceDB over Chroma is documented (ADR 0002) for hybrid search ergonomics. Retrieval pairs support offline Hit@k style checks.

5.6 Playbook generation

Prompts request structured JSON with containment, eradication, recovery, and lessons-learned phases. Outputs parse through resilient parse_llm_json (fences, trailing commas). Citations must subset the KB allow-list; low grounding triggers HiTL.

5.7 HiTL policy

Critical severity and low grounding force review. Reviewers approve/reject with comments; race conditions yield 409. Audit records decisions.

5.8 Investigation workspace

Single case screen: Case, Evidence, Timeline, Graph/Assets/Users, TI, MITRE, Notes, Playbooks, RCA, AI investigator stream. URL tab state supports shareable deep links.

5.9 LLM multi-provider and fallback

Settings catalog lists free and paid models across providers. Soft-allow unknown model IDs avoids hard 422 on catalog drift. Primary failure triggers cross-provider fallback; template path remains last resort.

5.10 Compliance and audit (Wave C)

Compliance module scores control alignment and surfaces gaps/evidence. Audit events form a hash chain; summary/integrity APIs support executive export packages for board-facing narratives.

Chapter 6 - Implementation

6.1 Technology stack

Layer Technology
Backend Python 3, FastAPI, Pydantic, pytest
Frontend React, CRA/Vite-compatible SPA patterns, Recharts
Data MongoDB, LanceDB
AI Multi-provider LLM APIs, hybrid RAG
E2E Playwright
Ops Docker Compose, Kubernetes/Helm, GitHub Actions

6.2 Backend modules (selected)

Module Role
parsers.py / broader parsers Multi-format ingest
ioc_extractor.py IoC extraction
enrichment.py TI live/mock
attack_mapping.py ATT&CK heuristics
vector_rag / KB Hybrid retrieval
playbook_agent Structured IR playbooks
hitl_gate.py Review policy
llm_provider Catalog + fallback
analytics_service KPIs v3 (events, IoCs, techniques)
compliance / audit Score, chain, export
golden_eval.py Offline IR benchmark

6.3 Frontend routes (selected)

Login - Dashboard - Upload - Incidents - Incident Workspace - Hunt - Analytics - Review - Audit - Compliance - Knowledge - Settings - Ops Health - Golden Benchmark - Roadmap

Dashboard uses Promise.all for atomic KPI/incident load, formatMetricValue for stable formatting, and opt-in only REACT_APP_DASHBOARD_DEMO_FALLBACK (unset = live data / honest zeros).

6.4 Configuration and secrets

.env + Settings vault; secrets never returned in plaintext via API. Weak JWT rejected outside lab modes. OIDC scaffold present but password login is default.

6.5 Notable APIs

OpenAPI: docs/openapi.json. Dual mount /api and /api/v1. Key groups: auth, upload/jobs, incidents/workspace, review, hunt, settings/LLM catalog, compliance, audit, eval/golden.

6.6 CI/CD

GitHub Actions run unit/integration tests, golden IR gates, and related checks. Playwright smoke covers critical UI paths (maintain testids as UI evolves).

Chapter 7 - Testing & evaluation

7.1 Test strategy

```
| Layer | Scope |
| Unit | Parsers, JSON resilience, HiTL, RBAC, audit |
| Integration | Pipeline isolation, enrichment mock, workspace APIs |
| Golden offline | 37-case IR metrics (no Mongo/LLM required) |
| E2E | Playwright smoke / flows |
| Manual | Demo script, screenshot pack, TI live keys |
```

Master catalog: appendices/A_test_case_catalog.md (TC-AUTH, TC-ING, TC-TI, TC-ATK, TC-AI, TC-RAG, TC-HITL, TC-WS, TC-DASH, TC-CMP, TC-AUD, TC-RES, ...).

7.2 Golden IR results (2026-07-26)

```
| Metric | Threshold | Result | Pass |
| n_cases | >= 30 | 37 | OK |
| mean_ioc_f1 | >= 0.85 | 0.982 | OK |
| mean_technique_recall | >= 0.80 | 0.930 | OK |
| mean_grounding | >= 0.50 | 1.000 | OK |
| full_phase_fraction | >= 1.0 | 1.000 | OK |
| mean_latency_s | <= 7.0 | 0.001 | OK |
| n_errors | 0 | 0 | OK |
| failures | [] | [] | OK |
```

Command: `pytest backend/tests/test_golden_benchmark.py -q` (from repo conventions).

7.3 Broader automated suite

Representative suites (compliance, audit, LLM provider, RBAC, hunt, golden) were executed in development with 51+ tests passed on the Wave C resilience branch. Full matrix status should be filled in Appendix A after formal sign-off runs.

7.4 RAG / retrieval notes

Hybrid search returns scored hits; BM25 remains available if vectors are disabled. Retrieval pairs support offline checks; full RAGAS board metrics remain optional future work (not required for golden CI).

7.5 Security tests

RBAC matrix denies analyst settings mutation and unauthorized review. Hardening tests cover weak secrets, lockout, and session behavior. Prompt-injection notes are delimited without tool execution.

7.6 Usability / demo path

docs/DEMO_SCRIPT.md targets a <10 minute golden path: login -> sample upload -> workspace -> playbook/grounding -> HiTL approve -> compliance/audit glance. 5-minute video is a student deliverable for viva.

7.7 Limitations of evaluation

- * Live LLM quality is not gated offline (template path dominates CI)
- * Mock TI is default without keys
- * Heuristic ATT&CK can false-positive technique IDs
- * Load/perf is pilot-class, not 500-user certified
- * E2E testid drift may require maintenance

Chapter 8 - Results & discussion

8.1 Product outcomes vs Project 4

Capstone expectation	ACTIRA outcome
Log parse + IoC	Multi-format + golden F1 ~0.98
TI enrichment	Multi-vendor + mock default
ATT&CK	Heuristic + heatmap + filters
RAG playbooks	Hybrid LanceDB + citations
HiTL	Severity + grounding gates
Dashboard	Live KPIs (demo opt-in)
Gradio UI baseline	React enterprise shell
Chroma baseline	LanceDB hybrid (ADR)
LangGraph multi-agent	Modular pipeline (honest framing)

8.2 Sample workflow outcomes

Analysts obtain: extracted IoCs, enrichment status (mock/live), technique list, playbook JSON with phases and citations, grounding score, optional RCA, and review state. Executives obtain compliance alignment and export packs without claiming certification.

8.3 Error analysis

Issue	Mitigation
False ATT&CK hits	HiTL + reviewer expertise
LLM JSON noise	parse_llm_json + template fallback
Empty dashboard misread	Live default; zeros when empty; no silent DEMO
Provider/model drift	Expanded catalog + soft-allow + fallback
Incident 404 hang	Explicit error/404 UI

8.4 Enterprise readiness

Board score 78/100 - Enterprise Pilot Ready (single-tenant). Strengths: documentation, AI IR narrative, workspace, golden eval, Wave C compliance/audit. Gaps: multi-tenant, full SSO JWKS, scale certification, remaining UX P0/P1 (Login marketing honesty, demo video/screenshots).

8.5 Screenshots

Capture figures into assets/screenshots/ and assets/figures/ (see those folders' READMEs). Insert as Figures 1-12 (Login, Dashboard, Upload, Incidents, Workspace, Graph, Playbook, Review, Hunt, Compliance, Settings LLM, Architecture).

Chapter 9 - Challenges & mitigations

#	Challenge	Mitigation in ACTIRA
1	Large-scale logs	Job queue, ZIP limits; not real-time SIEM
2	Correlation accuracy	Heuristic ATT&CK + timeline + HiTL
3	False positives	Grounding score + review queue
4	TI integration cost/keys	Multi-vendor + mock default + vault
5	Contextual IR quality	Hybrid RAG + NIST-style phases + citations
6	Scalability	Single-tenant pilot packaging
7	HiTL coordination	Review queue, claim, audit
8	Privacy / secrets	Vault, RBAC, redaction options

Chapter 10 - Conclusion & future work

10.1 Conclusion

ACTIRA delivers a complete capstone-grade human-gated AI IR advisor: multi-format ingest, IoC/TI/ATT&CK, hybrid RAG playbooks, investigation workspace, HiTL, audit integrity, compliance alignment, multi-provider LLM resilience, and offline golden evaluation with strong CI metrics. It meets and exceeds TalentSprint Project 4 baseline expectations while remaining honest about non-goals versus hyperscale SIEM/XDR.

10.2 Future work

Horizon	Items
Submission close	Demo video, screenshot pack, Login honesty
Next release	SSO JWKS, rate limits, E2E expansion, Analytics error polish
v2.0	Multi-tenant, connectors, commercial pilot
v3.0	Gated SOAR, forensics agent, formal multi-agent roster UX, RAGAS board

10.3 Ethical statement

ACTIRA is advisory. High-risk recommendations require human accountability. AI outputs must not be treated as unsupervised execution authority. Evaluators and operators should verify citations and TI freshness before action.

References

1. TalentSprint / IISc track - Capstone Projects List (GenAI C2), Project 4 brief.
2. Lewis, P. et al. (2020). Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks.
3. MITRE ATT&CK Framework - <https://attack.mitre.org/>
4. NIST SP 800-61 - Computer Security Incident Handling Guide.
5. Vendor documentation: AbuseIPDB, VirusTotal (and configured TI providers).
6. Internal product docs and this pack: docs/capstone/* (board, appendices, presentation).
7. Enterprise board review: board/CAPSTONE_BOARD_REVIEW_AND_SUBMISSION.md (2026-07-26).

Appendices

All full appendix bodies live under appendices/ in this pack (not external repo paths). Summary index:

```
| App | File | Contents |
| A | appendices/A_test_case_catalog.md | Master test catalog (TC-IDs, commands, status table) |
| B | appendices/B_api_surface.md | Dual /api + /api/v1 path surface extract |
| C | appendices/C_sample_outputs.md - C_sample_g001.json | Golden case g001 log -> IoCs, ATT&CK, playbook |
| D | appendices/D_configuration.md | Sanitized env/config (no secrets) |
| E | appendices/E_team_roles.md | Team / mentor / declaration (fill before viva) |
| F | appendices/F_glossary.md | Glossary of terms |
```

Folder index: appendices/README.md.

Appendix A - summary

Formal catalog with priorities and automation map. Mark Pass/Fail after formal runs. Representative automated evidence: golden suite all green (37 cases); Wave C related suites 51+ passed on development branch.

Appendix B - summary

Cookie-authenticated modular API; capability groups: auth, ingest/jobs, incidents/workspace, review, hunt, analytics, settings/LLM, compliance, audit, KB, eval, ATT&CK, health. See full path table in Appendix B file.

Appendix C - summary (case g001)

```
| Item | Result |
| IoC | 185.220.101.45 (ip) |
| Technique | T1110 Brute Force |
| Phases | containment -> eradication -> recovery -> lessons_learned |
| Grounding | 1.0 (template) |
| Provider | template |
```

Appendix D - summary

Required: MONGO_URL, DB_NAME, JWT_SECRET, CORS_ORIGINS, ENV. Optional LLM/TI keys; FORCE MOCK_TI for CI; omit REACT_APP_DASHBOARD_DEMO_FALLBACK for live dashboard data.

Appendix E - summary

Fill names, roles, mentor, and signatures in appendices/E_team_roles.md.

Appendix F - summary

Key terms: ACTIRA, HiTL, IoC, RAG, RRF, CES, Grounding, Alignment score (? certification). Full table in Appendix F file.

Assets for figures

```
| Path | Use |
| assets/screenshots/ | UI screenshots for report figures |
| assets/figures/ | Architecture / flow diagrams |
```

End of project report draft. Export to institute PDF template; keep claims consistent with board review (78/100 pilot) and golden metrics above. Keep all submission artifacts under docs/capstone/.

A_test_case_catalog.md

Appendix A - Master Test Case Catalog (Capstone Submission)

Location: docs/capstone/appendices/A_test_case_catalog.md
Product: ACTIRA - Agentic Cybersecurity Threat Intelligence & Incident Response Advisor
Purpose: Formal test catalog for evaluation report, viva, and regression evidence
Last updated: 2026-07-26
Automation map: pytest (backend/tests/), Playwright (frontend/e2e/), manual (M)
Parent report: ../PROJECT_REPORT.md

Legend

Field	Values
Priority	P0 Critical - P1 High - P2 Medium - P3 Low
Type	Functional - Security - API - UI - Performance - AI/RAG - Integration
Automation	Auto (pytest/Playwright) - Semi - Manual
Status	Pass / Fail / Blocked / Not run

1. Traceability to Capstone Project 4

Capstone capability	Test IDs
Log parse & IoC extract	TC-ING-001..., TC-PAR-001...
TI enrichment	TC-TI-001...
ATT&CK mapping	TC-ATK-001...
RAG + playbook	TC-AI-001..., TC-RAG-001...
HiTL	TC-HITL-001...
Dashboard	TC-DASH-001...
Investigation workspace	TC-WS-001...
Auth / RBAC	TC-AUTH-001...
Compliance / audit	TC-CMP-001..., TC-AUD-001...
Fallbacks / resilience	TC-RES-001...

2. Authentication & Authorization

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-AUTH-001	Login valid analyst	POST /auth/login with seeded analyst	200, cookie session, role analyst	P0	Security	Auto	
TC-AUTH-002	Login invalid password	Wrong password	401, lockout counter increments	P0	Security	Auto	
TC-AUTH-003	Lockout after N failures	Fail login >= threshold	Locked until window	P0	Security	Auto	
TC-AUTH-004	RBAC: settings mutate admin only	Analyst PUT /settings	403	P0	Security	Auto	
TC-AUTH-005	RBAC: review senior/admin	Analyst POST review	403	P0	Security	Auto	
TC-AUTH-006	Cookie session revalidate	Login -> GET /auth/me after 5m path	Role refreshed	P1	Security	Manual/Semi	
TC-AUTH-007	Logout clears cookie	POST /auth/logout	Subsequent API 401	P0	Security	Auto/e2e	
TC-AUTH-008	Weak JWT rejected outside lab	Start API with weak secret ENV=prod	Fail start / refuse	P0	Security	Auto	
TC-AUTH-009	Register creates analyst only	Public register	Role always analyst	P1	Security	Auto	
TC-AUTH-010	OIDC scaffold off by default	No OIDC env	Password login only	P1	Security	Manual	

3. Ingest & Parsing

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-ING-001	Single log upload	Upload apache/syslog sample	Job queued -> completed, incident created	P0	Integration	Auto/Manual	pipeline, smoke
TC-ING-002	Multi-file ZIP	Upload ZIP package	One correlated incident, multi_file flag	P0	Integration	Manual/Auto	pipeline
TC-ING-003	ZIP bomb protection	Oversized nested ZIP	Rejected / safe fail	P0	Security	Auto	pipeline isolation
TC-ING-004	Suricata EVE parse	Upload Suricata JSON sample	Events parsed to CES	P1	Functional	Auto	broader_parsers
TC-ING-005	Zeek parse	Zeek log sample	Parsed fields present	P1	Functional	Auto	broader_parsers
TC-ING-006	Sysmon JSON	Sysmon sample	Process fields extracted	P1	Functional	Auto	broader_parsers
TC-ING-007	Defender parse	Defender sample	Parsed	P1	Functional	Auto	broader_parsers
TC-ING-008	Job status polling	After upload poll jobs	status transitions visible	P0	UI/API	Manual/e2e	Upload page
TC-ING-009	Sample bundle button	Click Stage 3-File Bundle	Files staged in queue	P1	UI	Manual	Upload
TC-PAR-001	IoC IP extraction	Log with IPs	IoCs type=ip	P0	Functional	Auto	golden
TC-PAR-002	IoC domain/url/hash	Mixed log	Correct types	P0	Functional	Auto	golden
TC-PAR-003	Parser isolation failure	One bad file in batch	Other files still process	P1	Functional	Auto	pipeline_isolation

4. Threat Intelligence & ATT&CK

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-TI-001	Mock enrichment without keys	Clear TI keys, ingest	IoC enrichment mock=true	P0	Functional	Auto	enrichment
TC-TI-002	Live AbuseIPDB when keyed	Set key, ingest IP	mock=false when API ok	P1	Integration	Manual	enrichment
TC-TI-003	FORCE MOCK TI	Set env true	Always mock	P1	Functional	Auto	tests
TC-ATK-001	Keyword ATT&CK map	Brute force log	Techniques include T1110-class	P0	AI	Auto	attack_mapping, golden
TC-ATK-002	Heatmap counts	Open Dashboard heatmap	Counts match incidents	P1	UI	Manual	Dashboard
TC-ATK-003	Technique filter	Incidents ?technique=T1110	Filtered list	P1	Functional	Manual	Incidents
TC-ATK-004	Catalog matrix API	GET /attack/matrix	Columns/techniques	P2	API	Auto	attack_matrix

5. AI / RAG / Playbooks / Investigator

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-AI-001	Playbook structured JSON	Pipeline with LLM key	playbook.steps phases present	P0	AI	Semi	playbook_agent
TC-AI-002	Template fallback no key	Clear LLM keys, run pipeline	llm_provider=template, hitl likely	P0	AI	Auto	golden offline
TC-AI-003	Citation allow-list	Generated playbook	citation_ids ? KB	P0	AI	Auto	playbook
TC-AI-004	Grounding score range	Any playbook	0-1 float	P0	AI	Auto	golden
TC-AI-005	Cross-provider fallback	Primary fails, secondary key set	eff provider changes, log fallback	P1	AI	Semi	llm_provider
TC-AI-006	JSON parse resilience	Fenced/trailing comma LLM output	parse_llm_json succeeds	P0	AI	Auto	unit parse
TC-AI-007	Investigator SSE	Stream investigate	tokens + done	P1	AI	Semi	ai_investigator
TC-AI-008	Prompt injection note	Note with "ignore system"	Delimiters / no tool exec	P0	Security	Auto	


```
investigate_prompt_safety |
| TC-AI-009 | RCA fallback | No LLM budget/key | fallback RCA + reason | P1 | AI | Auto | test_rca |
| TC-RAG-001 | Hybrid search | KB search hybrid | Results with scores | P0 | AI | Auto | vector_rag |
| TC-RAG-002 | BM25 fallback | Vector disabled path | BM25 still works | P1 | AI | Auto | vector |
| TC-RAG-003 | Golden retrieval pairs | Offline retrieval eval | Hit@k thresholds | P1 | AI | Auto | retrieval |
| TC-GOLD-001 | Golden IR offline suite | pytest test_golden_benchmark | Pass CI gates | P0 | AI | Auto | golden-ci |
|
| TC-GOLD-002 | Golden UI run | Admin Golden page Run | Metrics render | P1 | UI | Manual | GoldenBenchmark |
```

6. HiTL / Review

```
| ID | Title | Steps | Expected | Priority | Type | Automation | Module |
| TC-HITL-001 | Critical forces review | Critical incident | hitl_required true | P0 | Functional | Auto | hitl_gate |
|
| TC-HITL-002 | Low grounding forces review | Low ground playbook | pending_review | P0 | Functional | Auto | hitl |
| TC-HITL-003 | Approve with comment | Reviewer approve + notes | status approved, audit entry | P0 | Functional |
Auto/e2e | review |
| TC-HITL-004 | Reject without comment | Empty comment | Client/server validation error | P0 | Functional | Manual |
Review UI |
| TC-HITL-005 | Double approve race | Concurrent approve | One 409, one success | P1 | Functional | Auto | review
claim |
| TC-HITL-006 | Review queue filters | Filter severity/threat | List updates | P2 | UI | Manual | ReviewQueue |
```

7. Investigation Workspace

```
| ID | Title | Steps | Expected | Priority | Type | Automation | Module |
| TC-WS-001 | Load incident | Open /incidents/:id | Case loads | P0 | UI | Auto | workspace tests |
| TC-WS-002 | 404 incident | Bad id | Error state not infinite load | P0 | UI | Manual | IncidentDetail |
| TC-WS-003 | Timeline API | GET timeline | Events ordered | P0 | API | Auto | workspace_views |
| TC-WS-004 | Entity graph | Assets/Users tabs | Graph/entities | P1 | UI | Auto | workspace |
| TC-WS-005 | Notes CRUD | Create note | Persists, audit | P0 | API | Auto | workspace_api |
| TC-WS-006 | RCA generate | POST rca | Narrative or fallback | P1 | AI | Auto | rca |
| TC-WS-007 | Tab URL state | Change tab | ?tab= updates | P2 | UI | Manual | WorkspaceTabs |
| TC-WS-008 | Similar cases | GET similar | List or disabled reason | P2 | API | Auto | similar |
```

8. Dashboard / Analytics / Hunt

```
| ID | Title | Steps | Expected | Priority | Type | Automation | Module |
| TC-DASH-001 | Live KPIs without demo flag | Open Dashboard, flag unset | Real Mongo counts; no DEMO banner | P0 |
UI | Manual | Dashboard |
| TC-DASH-002 | Empty tenant zeros | Fresh DB | Zeros/empty charts, not fake 65 incidents | P0 | UI | Manual |
Dashboard |
| TC-DASH-003 | Atomic load | Network throttle | KPIs+table paint together | P1 | Performance | Manual | Dashboard |
| TC-DASH-004 | KPI fields complete | GET /kpis | high/medium/events/iocs/top_techniques present | P0 | API | Auto |
analytics_service |
| TC-DASH-005 | Demo flag banner | Set REACT_APP_DASHBOARD_DEMO_FALLBACK=true empty DB | DEMO DATA banner | P1 | UI |
Manual | Dashboard |
| TC-AN-001 | Analytics window | Change 7/30 days | Charts refresh | P1 | UI | Manual/e2e | Analytics |
| TC-AN-002 | Analytics API error | Stop backend mid-page | Error message (not infinite load) | P1 | UI | Manual |
Analytics |
| TC-HUNT-001 | NL hunt PowerShell | Query "suspicious PowerShell" | Results scored | P0 | Functional | Auto |
hunting |
| TC-HUNT-002 | Behavior hotspots | Open Hunt | Hotspot cards if signals | P1 | Functional | Auto | behavior |
```

9. Compliance / Audit / Settings

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-CMP-001	Compliance status	GET /compliance/status	score, frameworks, domains	P0	API	Auto	compliance_score
TC-CMP-002	OIDC gap production	ENV=prod no OIDC	IAM-03 in gaps	P1	Functional	Auto	compliance_score
TC-CMP-003	Evidence pack download	UI button	JSON file	P1	UI	Manual	Compliance
TC-CMP-004	Executive export	GET executive-export	markdown + score	P1	API	Auto	executive_export
TC-AUD-001	Audit list normalize	Approve incident -> Audit page	analyst, incident_id, comment mapped	P0	Functional	Manual/Auto	audit
TC-AUD-002	Hash integrity	GET /audit/integrity	status ok/partial/legacy	P1	Security	Auto	audit_intelligence
TC-AUD-003	Summary narrative	GET /audit/summary	bullets + counts	P1	Functional	Auto	audit
TC-SET-001	Save LLM provider	Change provider+model, Save	Persists; toast shows pair	P0	UI	Manual	Settings
TC-SET-002	Invalid model soft warn	Custom model id	Warning not hard block	P1	UI	Manual	Settings
TC-SET-003	LLM catalog API	GET /settings/llm-catalog	free/paid lists	P1	API	Auto	executive_export routes
TC-SET-004	Test LLM	Admin test connection	ok or structured error	P2	Integration	Manual	Settings
TC-SET-005	Clear TI secrets	Confirm clear	has_* false, mock TI	P1	Security	Manual	Settings

10. API / Modular / Ops

ID	Title	Steps	Expected	Priority	Type	Automation	Module
TC-API-001	/api vs /api/v1 parity	Same path both prefixes	Same shape	P0	API	Auto	modular_api_v1
TC-API-002	OpenAPI drift	export --check	Match docs/openapi.json	P0	API	Auto	openapi-ci
TC-API-003	Health / ready	GET health/ready	mongo status	P0	Ops	Auto	smoke
TC-API-004	Metrics auth	GET metrics without admin	401/403	P1	Security	Auto	ops
TC-OPS-001	Multi-replica worker flag	ACTIRA_JOB_WORKER=0	No double process	P1	Ops	Auto	ha_multi_replica
TC-OPS-002	Retention purge dry	Ops retention path	Policy applied	P2	Ops	Auto	wave3

11. Security Suite

ID	Title	Expected	Priority	Automation
TC-SEC-001	No secrets in public settings	has_* only	P0	Auto
TC-SEC-002	Path traversal upload	Rejected	P0	Auto
TC-SEC-003	XSS in note title	Escaped in UI	P1	Manual
TC-SEC-004	CSRF cookie SameSite	Configured per CORS	P1	Manual
TC-SEC-005	Bandit / pip-audit CI	Green	P1	Auto CI
TC-SEC-006	Password policy	<12 rejected	P0	Auto

12. UI / E2E Smoke Matrix

ID	Flow	Expected	Automation
TC-E2E-001	Login -> Dashboard	KPIs load	Playwright smoke
TC-E2E-002	Upload sample -> job	Completes	workflow
TC-E2E-003	Open incident -> workspace tabs	Tabs switch	Manual (expand e2e)
TC-E2E-004	Review approve	Queue updates	smoke/workflow
TC-E2E-005	Theme toggle	Dark/light	theme-visual

```
| TC-E2E-006 | Logout | Login page | smoke |  
| TC-E2E-007 | Settings admin only | Analyst 403/redirect | smoke |
```

Known gap: Align testids (dash-ingest-cta, incidents-filter-severity, kb-page) - track as P1.

13. Performance (manual / harness)

```
| ID | Title | Expected | Priority |  
| TC-PERF-001 | Dashboard first paint | KPIs+table atomic; <3s lab | P1 |  
| TC-PERF-002 | KPI cache | Second /kpis faster (cache hit) | P2 |  
| TC-PERF-003 | Benchmarks smoke | benchmarks/run_benchmarks.py | P2 |  
| TC-PERF-004 | 10 concurrent uploads | No crash; jobs complete | P2 |
```

14. Execution Commands (for report appendix)

```
# Unit / backend (lab)  
cd backend  
python -m pytest tests -q --tb=line  
  
# Golden offline  
python -m pytest tests/test_golden_benchmark.py -q  
  
# Wave C / resilience  
python -m pytest tests/test_compliance_score.py tests/test_audit_intelligence.py  
tests/test_llm_fallback_catalog.py tests/test_executive_export.py -q  
  
# Frontend e2e (stack up)  
cd frontend  
npx playwright test e2e/smoke.spec.js  
  
---
```

15. Formal run summary (2026-07-26)

Command (repo root):

```
python -m pytest backend/tests/test_golden_benchmark.py \  
backend/tests/test_compliance_score.py \  
backend/tests/test_audit_intelligence.py \  
backend/tests/test_llm_fallback_catalog.py \  
backend/tests/test_executive_export.py \  
backend/tests/test_rbac_matrix.py \  
backend/tests/test_hardening.py -q  
  
| Suite | Total | Pass | Fail | Blocked | Date | Notes |  
| Golden IR + Wave C + RBAC + Hardening (combined) | 66 | 66 | 0 | 0 | 2026-07-26 | Exit 0, ~18s |  
| Golden IR only | - | Pass | 0 | 0 | 2026-07-26 | Thresholds met (F1 0.982, recall 0.930) |  
| Compliance / audit / LLM catalog / exec export | - | Pass | 0 | 0 | 2026-07-26 | Included in 66 |  
| Security (RBAC + hardening) | - | Pass | 0 | 0 | 2026-07-26 | Included in 66 |  
| Playwright smoke | - | Not run | - | - | - | Requires live stack; run before viva if time |  
| Manual P0 UI (Dashboard live, screenshots) | - | Partial | - | - | 2026-07-26 | Code honesty fixes landed; capture  
screenshots in assets/screenshots/ |
```

TC automation status (aggregate): automated TC groups covered by the suites above -> Pass. Manual/UI TC-IDs remain Not run until demo screenshot session.

Use this catalog as the Test Plan appendix in the project report. Re-run and update dates before final PDF if code changes.

B_api_surface.md

Appendix B - API surface (capstone extract)

Location: docs/capstone/appendices/B_api_surface.md

Source snapshot: curated from repository OpenAPI for submission (dual mount /api and /api/v1).

Total documented paths in source OpenAPI: 178

Mounts

Mount	Purpose
/api	Primary SPA and integrations
/api/v1	Versioned parity for modular clients

Selected endpoints (submission-facing)

Path	Methods
/api/analytics	GET
/api/analytics/retrieval-compare	GET
/api/attack/catalog	GET
/api/attack/catalog/{technique_id}	GET
/api/attack/matrix	GET
/api/audit	GET
/api/audit/integrity	GET
/api/audit/logs	GET
/api/audit/summary	GET
/api/audit/telemetry	POST
/api/auth/login	POST
/api/auth/logout	POST
/api/auth/me	GET
/api/auth/oidc/callback	GET
/api/auth/oidc/config	GET
/api/auth/oidc/login	GET
/api/auth/register	POST
/api/compliance/evidence-pack	GET
/api/compliance/executive-export	GET
/api/compliance/gaps	GET
/api/compliance/score	GET
/api/compliance/status	GET
/api/eval/golden-benchmark	GET POST
/api/health	GET
/api/hunt	GET
/api/hunt/behavior	GET
/api/hunt/suggestions	GET
/api/incidents	GET
/api/incidents/{incident_id}	GET
/api/incidents/{incident_id}/behavior	GET
/api/incidents/{incident_id}/citations	GET
/api/incidents/{incident_id}/investigate	POST
/api/incidents/{incident_id}/investigate/stream	POST
/api/incidents/{incident_id}/investigations	GET
/api/incidents/{incident_id}/similar	GET
/api/incidents/{incident_id}/workspace	GET
/api/incidents/{incident_id}/workspace/entity-graph	GET
/api/incidents/{incident_id}/workspace/notes	GET POST
/api/incidents/{incident_id}/workspace/notes/{note_id}	DELETE PATCH

```
| /api/incidents/{incident_id}/workspace/rca | GET POST |
| /api/incidents/{incident_id}/workspace/timeline | GET |
| /api/kb/custom | GET |
| /api/kb/custom/{doc_id} | DELETE |
| /api/kb/ingest | POST |
| /api/kb/lora/status | GET |
| /api/kb/lora/train | POST |
| /api/kb/reindex | POST |
| /api/kb/retrieval-eval | GET |
| /api/kb/search | GET |
| /api/kb/vector-status | GET |
| /api/kb/{doc_id} | GET |
| /api/kpis | GET |
| /api/logs/ingest | POST |
| /api/logs/ingest/raw | POST |
| /api/logs/jobs | GET |
| /api/logs/jobs/{job_id} | GET |
| /api/logs/jobs/{job_id}/events | GET |
| /api/logs/jobs/{job_id}/resume | POST |
| /api/logs/upload | POST |
| /api/logs/upload-batch | POST |
| /api/ready | GET |
| /api/review/queue | GET |
| /api/review/{incident_id} | POST |
| /api/settings | GET POST PUT |
| /api/settings/apply-profile | POST |
| /api/settings/clear-secrets | POST |
| /api/settings/email-outbox | GET |
| /api/settings/email-status | GET |
| /api/settings/llm-catalog | GET |
| /api/settings/profiles | GET |
| /api/settings/reset | POST |
| /api/settings/slack-status | GET |
| /api/settings/test-email | POST |
| /api/settings/test-llm | POST |
| /api/settings/test-slack | POST |
| /api/v1/analytics | GET |
| /api/v1/analytics/retrieval-compare | GET |
| /api/v1/attack/catalog | GET |
| /api/v1/attack/catalog/{technique_id} | GET |
| /api/v1/attack/matrix | GET |
| /api/v1/audit | GET |
| /api/v1/audit/integrity | GET |
| /api/v1/audit/logs | GET |
| /api/v1/audit/summary | GET |
| /api/v1/audit/telemetry | POST |
| /api/v1/auth/login | POST |
| /api/v1/auth/logout | POST |
| /api/v1/auth/me | GET |
| /api/v1/auth/oidc/callback | GET |
| /api/v1/auth/oidc/config | GET |
| /api/v1/auth/oidc/login | GET |
| /api/v1/auth/register | POST |
| /api/v1/compliance/evidence-pack | GET |
| /api/v1/compliance/executive-export | GET |
| /api/v1/compliance/gaps | GET |
| /api/v1/compliance/score | GET |
| /api/v1/compliance/status | GET |
| /api/v1/eval/golden-benchmark | GET POST |
| /api/v1/health | GET |
| /api/v1/hunt | GET |
| ... | (+54 more matching paths in full OpenAPI) |
```

Capability groups

Group	Examples
Auth	login, logout, me, register, OIDC scaffold
Ingest	logs/upload, jobs, batch
Incidents	list, detail, investigate stream
Workspace	timeline, graph, notes, RCA
Review / HiTL	queue, approve/reject
Hunt	NL hunt, behavior
Analytics / KPIs	dashboard metrics
Settings / LLM	catalog, vault, test-llm
Compliance	score, gaps, evidence, executive-export
Audit	list, integrity, summary
KB / RAG	search, ingest, vector-status
Eval	golden-benchmark
ATT&CK	catalog, matrix
Ops	health, ready

Notes for evaluators

- * Cookie session auth applies to most routes; RBAC enforced on mutate/admin paths.
- * This appendix is the submission-facing surface list kept inside the capstone pack.
- * Dual /api and /api/v1 prefixes share handlers for modular clients.

C_sample_outputs.md

Appendix C - Sample outputs

Location: docs/capstone/appendices/C_sample_outputs.md

Machine-readable twin: C_sample_g001.json

Offline template-playbook run for golden case g001 (brute-force SSH). No live LLM or TI keys required.

C.1 Input log (excerpt)

```
Jan 12 10:00:01 web01 sshd[1023]: Failed password for root from 185.220.101.45 port 45322 ssh2
Jan 12 10:00:02 web01 sshd[1024]: Failed password for admin from 185.220.101.45 port 45325 ssh2
Jan 12 10:00:03 web01 sshd[1025]: authentication failure for invalid user oracle from 185.220.101.45
```

C.2 Expected labels (golden)

```
| Field | Value |
| IoCs | ip:185.220.101.45 |
| Techniques | T1110 (Brute Force) |
| Playbook phases | containment, eradication, recovery, lessons_learned |
| Min grounding | 0.5 |
```

C.3 Offline prediction (template path)

```
| Field | Value |
| IoCs | ip:185.220.101.45 |
| Techniques | T1110 |
| Phases | containment, eradication, recovery, lessons_learned |
| Grounding score | 1.0 |
| Severity | medium |
| HiTL required | false (example; critical/low-grounding cases force review) |
| LLM provider | template |
```

Playbook steps (excerpt)

```
| # | Phase | Action (summary) | Citations |
| 1 | containment | Isolate hosts; preserve volatile evidence | NIST-800-61-4.3 |
| 2 | containment | Block malicious IoCs at perimeter/endpoint | T1110, PB-BRUTEFORCE |
| 3 | eradication | Remove artifacts; disable compromised accounts | T1110 |
| 4 | recovery | Restore, rotate credentials, validate integrity | T1110 |
```

C.4 How to reproduce

```
# From repository root (lab)
python -c "from pathlib import Path; from backend.golden_eval import run_offline_case,
load_golden_dataset; c=load_golden_dataset(Path('backend/tests/golden/dataset.json'))[0];"
```



```
print(run_offline_case(  
  
# Full golden CI gate  
python -m pytest backend/tests/test_golden_benchmark.py -q  
  
---
```

C.5 Screenshots / figures

Place demo screenshots in:

- * docs/capstone/assets/screenshots/
- * Architecture exports in docs/capstone/assets/figures/

See docs/capstone/assets/screenshots/README.md.

D_configuration.md

Appendix D - Configuration (sanitized)

Location: docs/capstone/appendices/D_configuration.md

Do not commit real secrets. Values below are templates only.

D.1 Config files

File	Purpose
backend/.env	Local secrets & bootstrap (never commit)
backend/.env.example	Documented template in product repo
frontend/.env	REACT_APP_BACKEND_URL
Admin -> Settings UI	Runtime ops + encrypted vault

Secret resolution: Mongo settings (decrypted) -> process environment / .env.

D.2 Infrastructure (required)

Variable	Example	Notes
MONGO_URL	mongodb://localhost:27017	Compose: mongodb://mongodb:27017
DB_NAME	soc_console	Lab may use test DB names
CORS_ORIGINS	http://localhost:3000	Exact browser origins
JWT_SECRET	>=32 random chars	Weak refused when ENV not lab
ENV	dev / test / production	Affects seed, JWT checks

D.3 Auth & session

Variable	Notes
SESSION_TIMEOUT_HOURS	JWT lifetime
FAILED_LOGIN_LOCKOUT	Lock after N failures
SEED_DEMO_USERS	Lab only dual-gate
ALLOW_PUBLIC_REGISTER	Lab default; disabled in prod/OIDC
OIDC_*	Optional SSO scaffold (JWKS hardening still roadmap)

D.4 LLM (optional for peak quality)

Variable	Notes
LLM_PROVIDER	anthropic \ openai \ gemini \ groq \ ...
LLM_MODEL	Provider model id
LLM_TEMPERATURE	e.g. 0.35
ANTHROPIC_API_KEY / OPENAI_API_KEY / GEMINI_API_KEY / GROQ_API_KEY	Or Settings vault
Cross-provider fallback	Configured via Settings / catalog

Without keys, pipeline uses template playbooks (golden CI path).

D.5 Threat intelligence

Empty keys -> mock enrichment.

FORCE MOCK_TI=true forces mocks (CI).

Optional keys (vault or env): ABUSEIPDB_API_KEY, VIRUSTOTAL_API_KEY, GREYNOISE_API_KEY, THREATFOX_API_KEY, OTX_API_KEY, SHODAN_API_KEY, ...

D.6 Pipeline / HiTL

Variable	Meaning
GROUNDING_THRESHOLD	Below -> HiTL
HITL_SEVERITY_MIN	At/above severity -> always HiTL
AUTO_APPROVE_GROUNDING_MIN	Never bypasses severity gate
CORRELATION_WINDOW_MINUTES	Correlation window

D.7 Frontend honesty

Variable	Meaning
REACT_APP_BACKEND_URL	API base
REACT_APP_DASHBOARD_DEMO_FALLBACK	Omit / false for live KPIs; set true only for empty-DB demo fill

D.8 Minimal lab .env skeleton (sanitized)

```
ENV=dev
MONGO_URL=mongodb://localhost:27017
DB_NAME=soc_console
JWT_SECRET=replace-with-32-plus-char-random-string
CORS_ORIGINS=http://localhost:3000
FORCE MOCK_TI=true
# LLM_* and TI keys optional

# frontend/.env
REACT_APP_BACKEND_URL=http://localhost:8001
# REACT_APP_DASHBOARD_DEMO_FALLBACK not set = live data
```

E_team_roles.md

Appendix E - Team roles & contributions

Location: docs/capstone/appendices/E_team_roles.md

Source of names: product Login page team strip (Group 1) + git authorship for primary integrator.

E.1 Project identity

Field Value
Project title Agentic Cybersecurity Threat Intelligence & Incident Response Advisor (ACTIRA)
Capstone # 4
Program Advanced Certification Programme in Agentic and Generative AI
Product codename ACTIRA
Team Group 1
Report date 26 July 2026

E.2 Team members (Group 1)

Name Primary focus (suggested)
1 Abhishek Patre (assign per team agreement)
2 Aditya Sharma (assign per team agreement)
3 Barshan Mukhar Das (assign per team agreement)
4 Gaurav Eary (assign per team agreement)
5 Nishant Ramesh Rao Patil (assign per team agreement)
6 Prajwal B R (assign per team agreement)
7 Praveen S N (assign per team agreement)
8 Sarvesh Sood Integration / docs / Wave C resilience (repo primary committer)
9 Sindhu Subramanya (assign per team agreement)
10 Vesalapu Satya Venkata Rupa (assign per team agreement)

Refine "Primary focus" columns before viva if your institute requires explicit workstream ownership.

E.3 Mentor / evaluator

Field Value
Mentor name (fill if assigned by TalentSprint / IISc track)
Institute / track Advanced Certification Programme in Agentic and Generative AI (TalentSprint / IISc track)
Evaluation board date (fill)

E.4 Contribution matrix (product workstreams)

Workstream Artifacts in this pack / repo
Pipeline / parsers / IoC Backend parsers, golden cases
RAG / playbooks / HiTL Hybrid LanceDB RAG, playbook agent, review queue
Frontend workspace / dashboard React SPA, live KPIs, investigation workspace
Security / RBAC / vault Auth, hardening tests, Settings vault

Compliance / audit Wave C	Score, integrity chain, executive export
Testing / golden CI	appendices/A_test_case_catalog.md, pytest golden suite
Report / PPT	PROJECT_REPORT.md, presentation/, this appendix pack

E.5 Declaration

We declare that this capstone work is our own (with documented use of open-source libraries and APIs), that claims match the board review and evaluation evidence in this pack, and that ACTIRA is presented as an advisory pilot product-not a certified SIEM/XDR replacement.

| Name | Signature | Date |

F_glossary.md

Appendix F - Glossary

Location: docs/capstone/appendices/F_glossary.md

Term	Definition
ACTIRA	Agentic Cybersecurity Threat Intelligence & Incident Response Advisor
Alignment score	Compliance readiness metric; not formal certification (ISO/SOC2)
ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge
BM25	Lexical ranking function used in hybrid RAG
CES	Common Event Schema - normalized event records after parse
Grounding	Score (0-1) of playbook support from retrieved citations
HiTL	Human-in-the-Loop - mandatory review gate for high-risk cases
IoC	Indicator of Compromise (IP, domain, URL, hash, ...)
LanceDB	Vector store used for hybrid retrieval (design choice vs Chroma)
Modular monolith	Single deployable backend with clear module boundaries
Mock TI	Deterministic enrichment when TI API keys are absent
NIST SP 800-61	Computer security incident handling guide (phase structure)
Playbook	Structured IR response steps with phases and citations
RAG	Retrieval-Augmented Generation
RCA	Root cause analysis narrative
RRF	Reciprocal Rank Fusion - combines BM25 and dense rankings
SOAR	Security Orchestration, Automation and Response (execution not unsupervised in ACTIRA)
SOC	Security Operations Center
Template playbook	Offline / no-LLM fallback IR structure used by golden CI
TI	Threat intelligence
Vault	Encrypted storage for API keys in Settings
Wave C	Product wave adding compliance score, audit intelligence, executive export